FRONT PAGE

Nombre Alumno / DNI	Andrés Ramirez Carroll 54977572M
Título del Programa	Higher National Diploma in Computing (Level 5)
N.º Unidad y Título	UNIT 5 – Security & Risks Management
Año académico	2025-2026
Profesor de la unidad	Roberto Peralta
Título del Assignment	Entrega Final.
Día de emisión	17/02/2026
Día de entrega	26/05/2026
Declaración del estudiante	Certifico que la presentación del assignment es completamente mi propio trabajo y entiendo completamente las consecuencias del plagio. Entiendo que hacer una declaración falsa es una forma de mala práctica. **Fecha:** 22-05-2026 **Firma del alumno:**

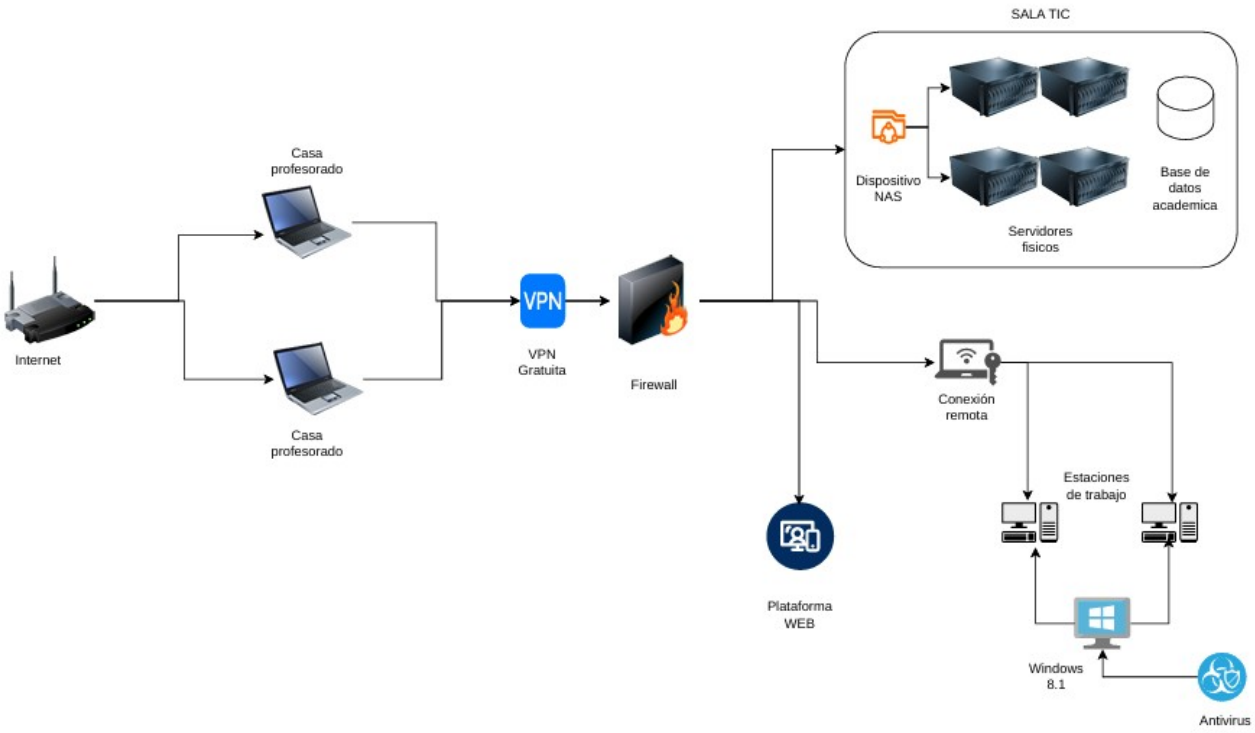
Plagio

El plagio es una forma particular de hacer trampa. El plagio debe evitarse a toda costa y los alumnos que infrinjan las reglas, aunque sea inocentemente, pueden ser sancionados. Es su responsabilidad asegurarse de comprender las prácticas de referencia correctas. Como alumno de nivel universitario, se espera que utilice las referencias adecuadas en todo momento y mantenga notas cuidadosamente detalladas de todas sus fuentes de materiales para el material que ha utilizado en su trabajo, incluido cualquier material descargado de Internet. Consulte al profesor de la unidad correspondiente o al tutor del curso si necesita más consejos.

INDICE

- Parte 1
- Mapa de red.
- Inventario de activos.
- Parte 2
- Análisis de riesgos.
- Parte 3
- Propuesta de mejoras.
- Parte 4
- Política de seguridad integral.
- Plan de respuesta ante incidentes.
- Plan de continuidad de negocio.
- Evaluación de idoneidad de herramientas.
- Bibliografía.

MAPA DE RED.



Este mapa de red, refleja la actual infraestructura de Centro Formación Campus Madrid.

INVENTARIO DE ACTIVOS.

Actualmente los activos de Centro Formación Campus Madrid se divide en cinco categorías distintas.

Hardware:
- Servidores físicos, son aquellos que albergan, correo, ficheros, base de datos académica y recursos humanos.
- Estaciones de trabajo, son los equipos que operan con el sistema operativo del centro.
- Dispositivo NAS, dispositivo conectado a los servidores encargado de realizar copias de seguridad y cuenta con un almacenamiento de 8tb de espacio.
- Sala TIC, es el espacio físico en donde se ubican los servidores.

Software:
- Firewall, software encargado de filtrar el trafico y proteger los sistemas, cuenta con una lista negra básica.
- Windows 8.1, sistema operativo que utilizan las estaciones de trabajo, no cuenta con soporte extendido.
- Plataforma virtual, pagina web académica la cual expone recursos y permite la entrega de trabajos por parte de los estudiantes.
- VPN, túnel privado para la conexión entre dispositivos.
- Escritorio remoto, aplicación que permite la conexión desde los ordenadores personales del profesorado hacia las estaciones de trabajo.
- Antivirus, sistema de protección diseñado para el escaneo de USB.

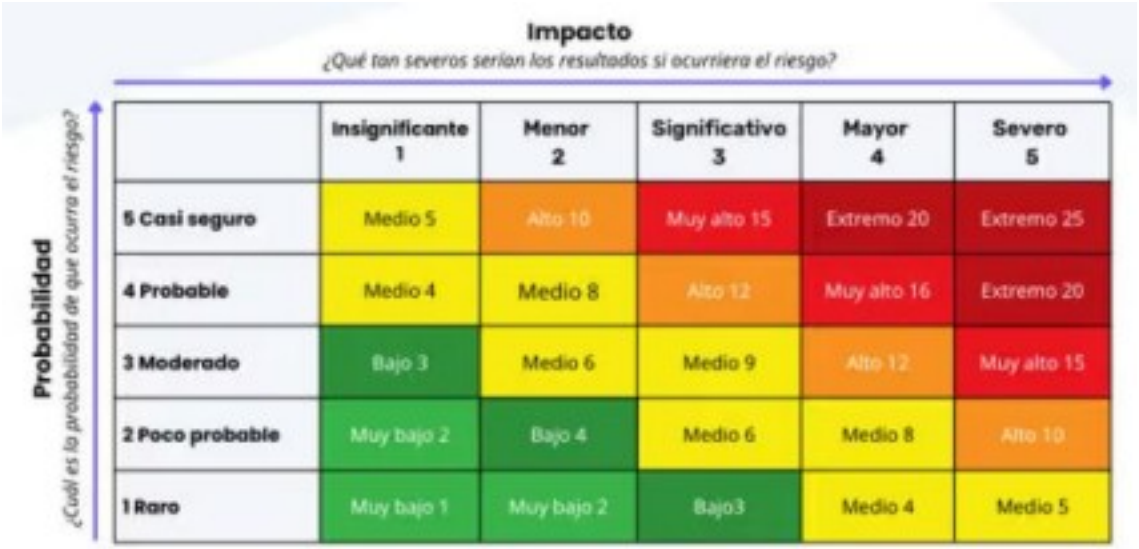
Datos e información:
- Base de datos académica, almacena todos los datos de los estudiantes.
- Datos financieros, es la información económica del centro.
- Datos de recursos humanos, información privada sobre los 70 distintos empleados.
- Correo, sistema de comunicación del centro.

Recursos humanos:
- Estudiantes, el centro cuenta con un total de 1.800 alumnos matriculados.
- Empleados, el centro cuanta con un total de 70 empleados divididos en distintos departamentos.

Procesos:
- Política de uso aceptable, se dispone de una política centrada en los alumnos pero actualmente está obsoleta.

ANÁLISIS DE RIESGOS.

Para poder realizar un análisis de riesgos lo mas exacto posible se procede a utilizar la siguiente métrica.



	Insignificante 1	Menor 2	Significativo 3	Mayor 4	Severo 5
5 Casi seguro	Medio 5	Alto 10	Muy alto 15	Extremo 20	Extremo 25
4 Probable	Medio 4	Medio 8	Alto 12	Muy alto 16	Extremo 20
3 Moderado	Bajo 3	Medio 6	Medio 9	Alto 12	Muy alto 15
2 Poco probable	Muy bajo 2	Bajo 4	Medio 6	Medio 8	Alto 10
1 Raro	Muy bajo 1	Muy bajo 2	Bajo3	Medio 4	Medio 5

En este análisis se toma como referencia todos los activos listados anteriormente, se procede a realizar una lista según el orden especificado y una justificación acorde al resultado.

- Servidores físicos: Los servidores sufren ataques como el DDoS o SQL injection, que se centra en denegar la disponibilidad de un sistema e infiltrarse en un sistema (Amazon Web Service, s.f.), son ataques que influyen en la continuidad de la empresa/centro, los servidores están ubicados en una sala que habitualmente suele permanecer abierta, esto aumenta el riesgo a un ataque físico (Jurado, A. s.f.), si un atacante consigue realizar un ataque de SQL injeciton exitoso pone en peligro los datos de 1.800 estudiantes alojados en la base de datos académica (Roviralta Puente, J.M 2021), es por ello que se le atribuye una probabilidad de 4 y un impacto de 5 haciendo un total de 20.
- Estaciones de trabajo: Las estaciones son susceptibles a ser vulneradas e integradas como equipo zombi dentro de una red botnet (Red Hat Documentation, s.f.), utilizan un sistema operativo Windows 8.1 sin soporte extendido, una VPN de uso gratuito y una conexión posible por escritorio remoto, el hecho de que se use una VPN gratuita ya es algo que genera inquietud, un sistema que no cuenta con soporte extendido y una posible conexión remota, esto genera un vector de ataque directo hacia la red interna sin medidas de contención, por ello se le asigna una probabilidad de 5 y un impacto de 4 haciendo un total de 20.
- Dispositivo NAS: Los dispositivos NAS son susceptibles a los ataques de ransomware que se dedican a cifrar la información almacenada por los mismos (Nakivo, 2024), esto podría conllevar en un rescate millonario debido a que este sistema se está utilizando para realizar backups de seguridad periódicos por ello se le asigna una probabilidad de 5 y un impacto de 5 haciendo un total de 25.

- Sala TIC: La sala es susceptible a ataques físicos como ingeniería social, vandalismo o desastres naturales, estos ataques son menos probables al paso del tiempo debido a que se conciencia al personal en estos ámbitos, por ello se le asigna una probabilidad de 2 y un impacto de 3 haciendo un total de 6.
- Firewall: El firewall esta configurado con listas negras conocidas y la ausencia de un antivirus local, al no tener un antivirus que escanee los ordenadores periódicamente estamos vulnerando los sistemas deliberadamente, combinado con un firewall que opera con listas negras conocidas sin WAF se vuelve un vector de ataque principal (Radware, s.f.), es por ello que se le asigna una probabilidad de 5 y un impacto de 5 haciendo un total de 25.
- Plataforma virtual: La plataforma virtual puede ser susceptible a ataques por SQL injection o XSS si el atacante ha conseguido entrar a la plataforma, estos ataques comprometen los datos de todos los alumnos (García de Zuñiga, F. 2026), es por ello que se le asigna una probabilidad de 3 y un impacto de 5 haciendo un total de 15.
- Alumnos: La falta de formación y concienciación en los alumnos incrementa la probabilidad de éxito en ataques, esto se debe a que no están formados o concienciados de la manera correcta sobre el uso de descargas o la confianza ciega en correos de procedencia sospechosa, esto puede desembocar en ataques de phishing (Palo Alto Networks, s.f.) o de malware, por ello se le asigna una probabilidad de 4 y un impacto de 3 haciendo un total de 12.
- Docentes: Al igual que los alumnos son susceptibles a ataques de phishing como se describe en el informe, los docentes también son susceptibles a ataques de ingeniería social o de malware mediante descarga oculta (Kaspersky, s.f.), aunque cuenten con una VPN esta es de uso gratuito lo cual deja mucho que desear, por ello se le asigna una probabilidad de 3 y un impacto de 5 haciendo un total de 15.
- Políticas: El uso de políticas obsoletas centradas en estudiantes es uno de los mayores riesgos existentes, debido a que no se sigue la RGPD/GDPR (Reglamento General de Protección de Datos) el centro esta obligado a cifrar los datos sensibles que maneja (PowerData, s.f.), el no seguimiento de esta ley puede conllevar un castigo muy severo, no se sigue la ISO 27001 la cual es crucial para preservar la confidencialidad , integridad y disponibilidad de la información (ISOTools, s.f.), además no se cumple la ISO 27002 que se puede tratar como complemento de la ISO 27001 (GlobalSuite Solutions, 2025), es por ello que se le asigna un probabilidad de 5 y un impacto de 5 haciendo un total de 25.

Habiendo identificado estos riesgos, se puede asumir que el centro está en una situación muy delicada ya que es susceptible a varias brechas de seguridad que pueden ser dirigidas desde varios ángulos de la infraestructura, el cambio de las políticas debería de ser el primer paso para mejorar la seguridad dentro y fuera del centro, una vez resueltos estos principales riesgos se puede empezar a mejorar la actual estructura del centro.

PROPUESTA DE MEJORAS.

Servidores físicos: Los servidores se encuentran en una sala abierta, son susceptibles a ataques de denegación de servicio y ataques de inyección sql. Se proponen las siguientes mejoras, restringir el acceso a la sala TIC donde se encuentran los servidores (QSM, s.f.), contratar un servicio de mitigación y monitorización activa contra ataques de denegación de servicio (Cloudflare, s.f.a) y debemos, validar y sanear las entradas a las bases de datos, establecer una lista blanca e implementar el Principio de Mínimo Privilegio (Axarnet, s.f.). Estas acciones previenen intrusiones físicas, garantizan la disponibilidad de los servicios del centro y protegen la integridad de los datos académicos.

Estaciones de trabajo: Los ordenadores que se usan en las estaciones de trabajo utilizan Windows 8.1 sin soporte extendido, una VPN de uso gratuito, una posible conexión por escritorio remoto y son susceptibles a un uso de maquina esclava. Se proponen las siguientes mejoras, una migración de software a una versión con soporte (Lisa Institute, s.f.), contratar un servicio de VPN de pago, habilitar la opción de autenticación a nivel de red (NLA) (TSPlus, s.f.) e implementar un servicio de antivirus local. Estas acciones garantizan una protección de vulnerabilidades donde tenemos sistemas sin soporte oficial, se refuerza la seguridad y privacidad de las conexiones remotas por parte del profesorado y se reducen drásticamente las probabilidades de que los ordenadores acaben siendo parte de una red de pc zombi (botnet).

Dispositivo NAS: Este dispositivo se esta utilizando para realizar copias de seguridad periódicas de los servidores, esto lo hace susceptible a ataques de ransomware. Por ello se proponen las siguientes mejoras, desactivar el inicio de sesión automatico, utilizar contraseñas seguras y una autentificación en dos pasos (MFA) (Smith, I. 2023), protección de acceso IP mediante una IP estática, esto permite configurar reglas en el firewall para que solo los servidores de la Sala TIC se conecten, y habilitar el cifrado de los datos almacenados. Estas acciones blindan el acceso desconocido al dispositivo, garantiza que la información sea ilegible para terceros en caso de robo o infiltración y permite al centro recuperarse ante incidentes sin la necesidad de ceder ante la extorsión o rescate económico.

Sala TIC: Espacio donde se guardan los servidores de la institución, es susceptible a ataques físicos, ingeniería social, vandalismo o desastres naturales. Se proponen las siguientes mejoras, mantener la sala cerrada, controlar el acceso y concienciar a los empleados sobre la importancia de no aceptar USB o discos que provengan de fuentes desconocidas. Estas acciones blindan el espacio físico de la sala, permite establecer uno o varios protocolos de actuación y prevención ante desastres.

Firewall: Medida de seguridad que opera con listas negras básicas y un antivirus dedicado únicamente a la lectura de USB. Esto lo hace susceptible a accesos no autorizados, explotación de vulnerabilidades conocidas y una infiltración de malware. Se proponen las siguientes mejoras, una implementación de un servicio firewall de aplicaciones web (WAF) que permita segmentar una DMZ para aislar la plataforma virtual y aplicar NAT para ocultar de terceros las estaciones de trabajo de los docentes, un análisis y cierre de los puertos innecesarios y desplegar un antivirus especializado en detectar malware. Estas acciones permiten realizar una inspección profunda del tráfico para mitigar ataques de capa de aplicación, minimizar la superficie de ataque externa y garantizar una seguridad integral en tiempo real.

Plataforma Virtual: Esta plataforma se usa como portal de subida de trabajos académicos, lo cual lo hace susceptible a ataques de inyección sql y Cross-Site Scripting (XSS). Se proponen las siguientes mejoras, sanear y validar las entradas a la base de datos académica (Cloudflare, s.f.b), establecer una lista de entradas permitidas, hacer uso de el Principio de Mínimo Privilegio, concienciación sobre los correos, mensajes o enlaces de procedencia desconocida (Cloudflare, s.f.c). Estas acciones permiten asegurar las calificaciones y datos de los estudiantes y evitan que se comprometan las sesiones de los administradores.

Políticas de seguridad: El marco político actual esta obsoleto, esta enfocado en el alumnado e incumple directamente los requisitos de la Ley de Protección de Datos (GDPR) y los estándares ISO 27001/27002 dejando los datos del alumnado sin protección. Se proponen las siguientes mejoras, políticas de uso aceptables para todo el personal no solo el alumnado y el cifrado de todos los datos sensibles almacenado en la base de datos académica. Estas acciones protegen directamente los datos ante cualquier intento de ransomware, garantiza la confidencialidad de los datos y asegura el cumplimiento legal del centro, evitando sanciones económicas y graves responsabilidades legales.

Como ampliación técnica para mitigar fallos por configuraciones incorrectas de firewall o accesos remotos, se propone integrar los siguientes tres mecanismos de arquitectura seguro : * **DMZ (Zona Desmilitarizada):** Su función es aislar los servidores de acceso público de la red interna (LAN). *Ejemplo en el centro:* Al ubicar la Plataforma Virtual en una DMZ, si un atacante explota una inyección SQL o un XSS, el compromiso se confina en ese segmento perimetral, impidiendo que salte lateralmente hacia la base de datos académica .

POLÍTICA DE SEGURIDAD INTEGRAL.

La siguiente política se crea estableciendo ocho puntos clave (Grupo Atico34, s.f.).

Objetivo: Esta política de seguridad se crea para poder proteger los datos sensibles que se almacenan en los servidores del centro.

Alcance: Esta política afecta directamente al proceso de guardado de los datos de los estudiantes, docentes y empleados del centro.

Principios: La política se crea con el principio de confidencialidad y cumplimiento normativo establecido por el RGPD/GDPR y opera a través del principio de mínimo privilegio. Asimismo, se reconoce el impacto en la seguridad de la des-alineación con los estándares ISO 27001 y 27002. No alinear la seguridad técnica con las políticas debilita los controles, incrementando la superficie de ataque ante intrusiones, en caso de ransomware estaríamos contradiciendo la ley de RGPD.

Compromiso de la dirección: La dirección se ve comprometida a asegurar la confidencialidad, integridad y disponibilidad de los datos almacenados por el centro.

Roles y responsabilidades: Los roles y responsabilidades se dividen en dos grupos: 1. El departamento de dirección se ve obligado a la protección de los datos sensibles de los estudiantes cuando se recrean en certificados o resultados de notas. 2. El departamento informático del centro se ve obligado a proteger los datos almacenados mediante un cifrado y una revisión periódica de los sistemas.

Normas: Para que la política sea robusta se deben seguir las siguientes normas/normativas: 1. Cifrado de datos sensibles, según la RGPD/GDPR todos los datos sensibles que sean almacenados deben ser cifrados bajo máxima seguridad. 2. Implementación, mantenimiento y mejora continua de los sistemas informáticos, estos requisitos impuestos por la normativa ISO-27001 (Estrategia Nacional, 2020) no solo mejoran la reputación del centro sino que permite al centro estar actualizado ante las nuevas amenazas. Las repercusiones organizativas con origen de una auditoria de seguridad, implica la ejecución de planes de acción que corrigen las vulnerabilidades halladas. 3. Protección eficiente de los activos, debemos implementar buenas practicas de uso y objetivos de control centrados en la seguridad informática, de esta manera cumplimos con la normativa ISO-27002 (Holoway, D. 2025).

Sanciones: Para las personas o grupos de personas que infrinjan estas normas, serán puestos bajo investigación, de ser una conspiración o actuaciones sospechosas para dañar la infraestructura del centro, se procederá a una sanción legal y económica según la gravedad de las actuaciones.

PLAN DE RESPUESTA ANTE INCIDENTES

Para poder elaborar un plan de respuesta ante incidentes de manera correcta y precisa, se va a seguir un modelo de seis puntos (Check Point, s.f.).

Preparación: En este punto debemos identificar a las partes interesadas de la organización, estas son: servidores fisicos, sala TIC, estaciones de trabajo, dispositivo NAS, firewall, plataforma virtual, alumnos y docentes. En caso de que sistemas informaticos sean comprometidos se procede a utilizar un canal de comunicación seguro como Signal, el cual utiliza las siguientes medidas de seguridad, cifrados de extremo extremo, usan claves de cifrado y se hace uso de PFS (Perfect Forward Secrecy) (FasterCapital, s.f.).

Evaluación: En este punto debemos identificar el alcance, gravedad e impacto del ataque, es por ello que el departamento de IT del centro debe determinar el alcance del ataque analizando el vector de entrada. Una vez se sabe el alcance, el departamento de IT debe bloquear todo el acceso a los servidores que almacenan los datos sensibles de los estudiantes, docentes y distintos empleados, para mitigar cualquier tipo de secuestro de datos.

Mitigación: Una vez conocemos el alcance del ataque debemos contenerlo, para ello aislaremos los equipos o sistemas que puedan haber sido comprometidos. Dependiendo del nivel de criticidad del ataque se deberá de actuar de una forma u otra, en caso de ser un ataque critico se debe desconectar físicamente el dispositivo, en caso de ser un ataque que no genera un peligro inminente debemos suspender y aislar el equipo del resto de la red del centro (libertia IT, s.f.), de esta manera podemos conservar los registros internos y recopilar evidencias para su posterior denuncia.

Respuesta: Una vez tenemos el sistema aislado o situado bajo un entorno controlado debemos tomar medidas correctivas, esto incluye la erradicación de malware y la recuperación de datos en caso de ser necesario. Para erradicar malware debemos descargar un antivirus avanzado esto ayuda al sistema de seguridad integrado del equipo (Malwarebytes, s.f.). Para recuperar datos perdidos en el ataque debemos utilizar una copia de seguridad reciente y verificada en un entorno controlado (Sosmatic, s.f.).

Recuperación: En este paso restauramos las actividades normales del centro de manera controlada, debemos revisar periódicamente tanto los sistemas afectados como los no afectados, esto permite una monitorización precisa y exhaustiva del comportamiento de la red.

Revisar: Una vez hemos restaurado las actividades normales del centro y estamos monitorizando pro activamente el estado de la red, debemos analizar e identificar la causa raíz del ataque, una vez que conocemos la causa debemos, revisar el plan ante incidentes y mejorarlo para futuras ocasiones.

PLAN DE CONTINUIDAD DE NEGOCIO.

Este plan es ejecutado en caso de ataque, su principal objetivo es la continuidad de las actividades educativas en el centro. Este plan se divide en 4 puntos (BBVA, s.f.).

Riesgos y como combatirlos: Actualmente se conocen cuatro riesgos críticos, en caso de ataque derivado de uno de estos se debe actuar con las medidas necesarias para la continuidad de la educación. Ransomware, en caso de ser afectado por este tipo de ataque debemos determinar que datos han sido cifrados, si no podemos averiguarlo deberemos usar una copia de seguridad anteriormente verificada y restaurar todos los archivos (Incibe_, s.f.). Bypass de lista negra, en caso de que un atacante eluda la seguridad del Firewall debemos contener la expansión por la red del centro aislando sistemas y poniendo en cuarentena los equipos que sean necesarios, una vez la amenaza queda contenida se procede a su erradicación. Inyección SQL, en el momento que la pagina web ha servido como portal para un ataque de sql-i debemos mitigar los daños posibles mediante una desconexión física del servidor, una vez hemos mitigado el vector de entrada procedemos a reinsertar el servidor con una copia de seguridad verificada a la red corporativa. Phishing, en caso de sufrir un ataque de phishing en el centro debemos reportar inmediatamente a las autoridades según corresponda, para prevenir este tipo de ataques debemos leer cuidadosamente toda clase de correo que provenga de fuentes sospechosas o desconocida.

Operativa indispensable: El centro cuenta con operativas que deben continuar independientemente del estado informático actual estas son: Actividad docente, los profesor deben seguir dando clase independientemente de si la pagina web del centro ha sufrido un ataque de sql-i la continuidad en la formación de los alumnos debe ser una prioridad dentro del centro, para asegurar que los alumnas siguen recibiendo su formación se procederá a usar métodos de aprendizaje mas básicos pero mas seguros. Disponibilidad de los datos académicos y financieros, el centro debe ser capaz de proteger y disponer de los datos académicos y datos financieros en todos los casos, los datos académicos y financieros deben ser accesibles mediante una administración aislada para prevenir su corrupción. Es por ello que se establece un plan de recuperación ante desastres con un tiempo de punto de recuperación (RPO) de 24 horas para mitigar la pérdida de información y un tiempo de recuperación objetivo (RTO) de 12 horas para restablecer el servicio.

Responsabilidades: En este bloque se delegan los roles que debe tomar cada departamento. Departamento de IT, este departamento cuenta con la mayor cantidad de responsabilidades debido a que son los encargados de proteger toda la infraestructura del centro por ello deben, proteger todos los datos sensibles almacenados y contener los ataques. Docentes, este departamento debe continuar la formación de los estudiantes independientemente de si la pagina web esta caída, deben adaptar sus clases, exámenes y proyectos para no perder el ritmo académico estructurado. Dirección, este departamento tiene la responsabilidad de reportar a las autoridades correspondientes en caso de brecha, en caso de caída debe ser capaz de comunicarlo a todo el centro.

Comunicación segura: Debido a que se ha decidido usar Signal como método de comunicación seguro en el plan ante incidentes, en este caso también se usara debido a que es una plataforma externa al centro y contiene una encriptado de extremo a extremo haciéndolo ideal para una continuidad de negocio.

EVALUACIÓN DE IDONEIDAD DE HERRAMIENTAS.

En cumplimiento con los objetivos de seguridad del centro, bajo las directrices de los estándares ISO 27001 / ISO 27002, se evalúa la idoneidad técnica de las soluciones tecnológicas elegidas para Centro de Formación Campus Madrid, con el objetivo de mitigar de forma definitiva las vulnerabilidades identificadas. Por ello se procede a una justificación de cada una.

Signal: Es una herramienta de comunicación muy acertada gracias a su arquitectura de cifrado de extremo a extremo y la implementación de PFS (Perfect Forward Secrecy). A diferencia de las soluciones corporativas tradicionales como correos corporativos que son vulnerables a ataques de phishing o interceptación si la red local se ve comprometida, Signal garantiza una vía de comunicación externa, e independiente de la infraestructura del centro .

WAF (Firewall de Aplicaciones Web): Esta herramienta es indispensable para garantizar la seguridad de la Plataforma Virtual. Mientras que el firewall del centro esta configurado con listas negras básicas, le es imposible detectar ataques lógicos, el WAF ayuda a monitorizar el tráfico entre una aplicación web e internet, lo que le permite bloquear de forma activa ataques de inyección sql y Cross-Site Scripting (XSS) (Cloudflare, s.f.d), protegiendo proactivamente los datos académicos de los alumnos y evitando el secuestro de sesiones de administrador de la página web.

VPN de pago y autenticación a nivel de red (NLA): Estas herramientas son ideales para proteger la conexión remota de los docentes a sus estaciones de trabajo. Sustituir la VPN gratuita por una de pago mejora la privacidad y seguridad del túnel. La activación de NLA exige una validación de identidad robusta antes de establecer la sesión de Escritorio Remoto, denegando de esta forma los ataques de fuerza bruta dirigidos hacia los ordenadores de las estaciones de trabajo configurados con Windows 8.1.

Autenticación Multifactor (MFA) y cifrado en el dispositivo NAS: Estas mejoras pretenden blindar proactivamente el dispositivo NAS encargado de realizar copias de seguridad sobre información sensible. El cifrado asegura el cumplimiento del la ley RGPD/GDPR al hacer ilegible la información sensible a terceros. El sistema de autenticación múltiple impide que los ataques de ransomware acaben con éxito en un gran porcentaje de los casos.

BIBLIOGRAFÍA.

Amazon Web Services (AWS) (s.f.): *¿Qué es un ataque DDoS?* Disponible en: https://aws.amazon.com/es/shield/ddos-attack-protection/ [Consulta: 25-04-2026] .

Axarnet (s.f.): "10 Consejos sobre seguridad en servidores y bases de datos". *Axarnet Blog*. Disponible en: https://axarnet.es/blog/seguridad-en-servidores [Consulta: 09-05-2026] .

BBVA (s.f.): *¿Qué es el plan de continuidad de un negocio?* Disponible en: https://www.bbva.es/finanzas-vistazo/ae/cuentas/plan-de-continuidad-de-un-negocio.html [Consulta: 21-05-2026] .

Check Point (s.f.): *The 6 Phases of an Incident Response Plan*. Disponible en: https://www.checkpoint.com/es/cyber-hub/cyber-security/what-is-incident-response/the-6-phases-of-an-incident-response-plan/ [Consulta: 21-05-2026] .

Cloudflare (s.f.a): *Cómo prevenir los ataques DDoS: métodos y herramientas*. Disponible en: https://www.cloudflare.com/es-es/learning/ddos/how-to-prevent-ddos-attacks/ [Consulta: 09-05-2026] .

Cloudflare (s.f.b): *Cómo prevenir la inyección de código SQL*. Disponible en: https://www.cloudflare.com/es-es/learning/security/threats/how-to-prevent-sql-injection/ [Consulta: 09-05-2026] .

Cloudflare (s.f.c): *Cómo prevenir los ataques XSS*. Disponible en: https://www.cloudflare.com/es-es/learning/security/how-to-prevent-xss-attacks/ [Consulta: 05-09-2026] .

Cloudflare (s.f.d): *¿Qué es un WAF? Explicación de Web Application Firewall*. Disponible en: https://www.cloudflare.com/es-es/learning/ddos/glossary/web-application-firewall-waf/ [Consulta: 21-05-2026] .

Estrategia Nacional (2020): "Normas UNE-EN ISO/IEC 27001 y UNE-EN ISO/IEC 27002 para la seguridad de la información". *Portal de Industria Conectada 40*, 28 de abril. Disponible en: https://www.industriaconectada40.gob.es/difusion/noticias/Paginas/Normas-UNE-EN-ISOIEC-27001-UNE-EN-ISOIEC-27002-seguridad-de-informaci%C3%B3n.aspx [Consulta: 21-05-2026] .

Faster Capital (s.f.): *Implementación De Canales De Comunicación Seguros*. Disponible en: https://fastercapital.com/es/tema/implementaci%C3%B3n-de-canales-de-comunicaci%C3%B3n-seguros.html/1 [Consulta: 21-05-2026] .

García de Zúñiga, F. (2026): "Ataque XSS o cross-site scripting: qué es y cómo evitarlo". *Blog de Arsys*, 23 de marzo. Disponible en: https://www.arsys.es/blog/ataques-xss-que-son-y-como-evitarlos [Consulta: 25-04-2026] .

GlobalSuite Solutions (2025): "¿Qué es la norma ISO 27002 y para qué sirve?". *GlobalSuite Blog*, 3 de diciembre. Disponible en: https://www.globalsuitesolutions.com/es/que-es-la-norma-iso-27002-y-para-que-sirve/ [Consulta: 25-04-2026] .

Grupo Atico34 (s.f.): *Política de seguridad de la información: Qué es y ejemplos*. Disponible en: https://protecciondatos-lopd.com/empresas/politica-seguridad-informacion/ [Consulta: 21-05-2026] .

Holloway, D. (2025): *La guía definitiva para ISO 27002*. Disponible en: https://es.isms.online/iso-27002/ [Consulta: 21-05-2026] .

Incibe (s.f.): *Cómo actuar en caso de un ataque de ransomware*. Disponible en: https://www.incibe.es/ciudadania/ayuda/ransomware [Consulta: 21-05-2026] .

ISOTools (s.f.): *Norma ISO 27001*. Disponible en: https://isotools.org/normas/riesgos-y-seguridad/iso-27001/ [Consulta: 25-04-2026] .

Jurado, A. (s.f.): "Amenazas de seguridad física para los sistemas de información". *Revista Digital INESEM*. Disponible en: https://www.inesem.es/revistadigital/gestion-integrada/amenazas-seguridad-fisica-sistemas-de-informacion [Consulta: 25-04-2026] .

Kaspersky (s.f.): *¿Qué es un ataque de descarga oculta?* Disponible en: https://www.kaspersky.es/resource-center/definitions/drive-by-download [Consulta: 25-04-2026] .

Libertia IT (s.f.): *Pasos Clave Tras Sufrir Un Ciberataque: Guía 2025 de Recuperación Para Empresas En Madrid*. Disponible en: https://libertia.es/pasos-claves-tras-sufrir-un-ciberataque/ [Consulta: 21-05-2026] .

Lisa Institute (s.f.): "¿Qué es un ataque botnet y cómo evitarlo?". *LISA Institute Blog*. Disponible en: https://www.lisainstitute.com/blogs/blog/ataque-botnet-como-evitarlo [Consulta: 09-05-2026] .

Malwarebytes (s.f.): *Cómo eliminar un virus de una computadora*. Disponible en: https://www.malwarebytes.com/es/cybersecurity/basics/how-to-remove-virus-from-computer [Consulta: 21-05-2026] .

Nakivo (2024): "Ataques de ransomware em dispositivos NAS". *Nakivo Blog*, 6 de mayo. Disponible en: https://www.nakivo.com/es/blog/ransomware-attacks-on-nas-devices/ [Consulta: 25-04-2026] .

Palo Alto Networks (s.f.): *¿Qué es un ataque de phishing?* Disponible en: https://www.paloaltonetworks.lat/cyberpedia/what-is-phishing [Consulta: 25-04-2026] .

PowerData (s.f.): *GDPR: Lo que debes saber sobre el reglamento general de protección de datos.* Disponible en: https://www.powerdata.es/gdpr-proteccion-datos [Consulta: 25-04-2026] .

QMS (s.f.): *Medidas de seguridad TIC en las empresas*. Disponible en: https://qms-spain.com/medidas-de-seguridad-tic-en-las-empresas/ [Consulta: 21-05-2026] . *(Nota: Corregido el nombre "QSM" por las siglas reales de la empresa y su URL).*

Radware (s.f.): *7 tipos de ataques más comunes para los que está diseñado el firewall de aplicaciones web (WAF)*. Disponible en: https://es.radware.com/cyberpedia/application-security/7-most-common-attack-types/ [Consulta: 25-04-2026] .

Red Hat Documentation (s.f.): *Amenazas a la estación de trabajo y a la seguridad del computador personal*. Disponible en: https://docs.redhat.com/es/documentation/red-hat-enterprise-linux/6/html/security-guide/sect-security-guide-attackers-and-vulnerabilities-threats-to-workstation-and-home-pc-security [Consulta: 25-04-2026] .

Roviralta Puente, J.M. (2021): "Ataques de inyección SQL, una amenaza para tu web". *INCIBE Blog*, 26 de octubre. Disponible en: https://www.incibe.es/empresas/blog/ataques-inyeccion-sql-amenaza-tu-web [Consulta: 25-04-2026] . *(Nota: Corregida la errata del año que ponía -021).*

Smith, I. (2023): "8 Sencillos pasos para proteger su NAS". *StorageReview*, 24 de julio. Disponible en: https://www.storagereview.com/es/review/8-simple-steps-to-secure-your-nas [Consulta: 09-05-2026] .

Sosmatic (s.f.): *Recuperación De Datos Tras Un Ciberataque: Qué Hacer Y Cómo Actuar*. Disponible en: https://www.sosmatic.com/recuperacion-de-datos-tras-un-ciberataque-que-hacer-y-como-actuar/ [Consulta: 21-05-2026] .

TSPlus (s.f.): "Autenticación a nivel de red RDP: Configuración, Seguridad y Casos de Uso". *TSPlus Blog*. Disponible en: https://tsplus.net/es/remote-access/blog/rdp-network-level-authentification/ [Consulta: 09-05-2026]